

Roadmap Tata Kelola Risiko Siber (Implementasi Bertahap)

DPMPTSP – Rencana Peningkatan yang Praktis dan Bertahap

1. Tujuan Roadmap

Roadmap ini menyediakan rencana bertahap dan realistis untuk memperkuat tata kelola risiko siber di DPMPTSP. Roadmap disusun berdasarkan kondisi saat ini (AS-IS) dan difokuskan pada perbaikan secara bertahap yang dapat dilaksanakan dalam lingkungan sektor publik dengan keterbatasan sumber daya.

2. Prinsip Dasar

Prinsip-prinsip berikut menjadi landasan dalam penyusunan roadmap ini, memastikan bahwa peningkatan tata kelola risiko siber dilakukan secara realistis, bertahap, dan sesuai dengan kondisi serta kapasitas DPMPTSP saat ini:

- Memulai dari praktik yang sudah ada dan memperkuatnya secara bertahap.
- Memprioritaskan tata kelola, peran, dan dokumentasi sebelum pengendalian teknis.
- Menghindari birokrasi berlebihan atau penggunaan alat yang kompleks.
- Menyelaraskan perbaikan dengan prinsip ISO/IEC 27005, ISO/IEC 27001, dan NIST SP 800-39.

3. Roadmap Tata Kelola Risiko Siber

Sebuah peta jalan tata kelola risiko siber bertahap dikembangkan untuk menyediakan pendekatan terstruktur dan realistis dalam meningkatkan praktik tata kelola di DPMPTSP. Peta jalan ini dirancang untuk mencerminkan kendala organisasi saat ini sekaligus memungkinkan pengembangan kematangan secara bertahap dan berkelanjutan.



Gambar 1. Roadmap Perbaikan Tata Kelola Risiko Siber

Gambar 1 menyajikan roadmap perbaikan Tata Kelola Risiko Siber, yang menggambarkan pendekatan tiga fase untuk peningkatan tata kelola dalam organisasi. Diagram ini memberikan gambaran umum tingkat tinggi tentang perkembangan dari praktik tata kelola dasar hingga mekanisme yang lebih terstruktur dan terintegrasi.

Penjelasan rinci dari setiap fase diberikan dalam subbagian berikut, di mana Tahap 1 berfokus pada pembentukan kemampuan dasar, Tahap 2 pada formalisasi proses, dan

Tahap 3 pada integrasi tata kelola ke dalam pengambilan keputusan organisasi dan peningkatan berkelanjutan.

3.1 Tahap 1: Fondasi (0–6 Bulan)

Tujuan: Membangun struktur dasar, visibilitas, dan akuntabilitas dalam tata kelola risiko siber.

Untuk mencapai tujuan tersebut, langkah-langkah awal berikut dirumuskan sebagai tindakan praktis yang dapat segera diterapkan sesuai dengan kondisi DPMPTSP saat ini dengan tahapan berikut ini:

- Menunjuk peran atau penanggung jawab untuk koordinasi risiko siber dan TI.
- Menggunakan Governance Checklist untuk mendokumentasikan kondisi saat ini.
- Menyusun Risk Register Risiko Siber kualitatif awal (5–10 risiko utama).
- Mensosialisasikan Alur Penanganan & Eskalasi Insiden kepada pihak terkait.
- Memulai pencatatan insiden secara sederhana (tanggal, sistem, dampak).

3.2 Tahap 2: Formalisasi (6–18 Bulan)

Tujuan: Memformalkan proses yang berulang dan meningkatkan konsistensi di seluruh organisasi.

Pada tahap ini, fokus diarahkan pada penyusunan dan penerapan proses yang terdokumentasi agar praktik pengelolaan risiko siber dapat dilakukan secara lebih konsisten dan berkelanjutan di seluruh unit kerja dengan langkah-langkah dibawah ini:

- Menyusun kebijakan keamanan siber dasar yang disetujui pimpinan.
- Menetapkan dan mendokumentasikan prosedur penilaian risiko siber yang sederhana.
- Melaksanakan pelatihan kesadaran keamanan siber secara berkala (minimal setahun sekali).
- Melakukan peninjauan dan pembaruan Risk Register Risiko Siber secara periodik.
- Menerapkan pelaporan dasar risiko dan insiden siber kepada pimpinan.

3.3 Tahap 3: Integrasi dan Kematangan (18–36 Bulan)

Tujuan: Mengintegrasikan tata kelola risiko siber ke dalam tata kelola dan perencanaan organisasi secara menyeluruh.

Pada tahap ini, organisasi mulai memperkuat pendekatan tata kelola dengan memastikan bahwa pengelolaan risiko siber terhubung langsung dengan proses perencanaan, pengambilan keputusan, dan evaluasi kinerja organisasi. Fokus

diarahkan pada penyelarasan lintas fungsi, penguatan mekanisme evaluasi, serta peningkatan kematangan secara bertahap dan berkelanjutan dengan cara berikut:

- Menyelaraskan tata kelola risiko siber dengan inisiatif SPBE dan koordinasi Diskominfo.
- Menerapkan peninjauan tata kelola secara berkala dan audit internal sederhana.
- Menyempurnakan proses penanganan insiden dan pembelajaran dari insiden.
- Mengembangkan metrik dan indikator sederhana untuk risiko siber dan kesadaran keamanan.
- Mempertimbangkan penyelarasan dengan persyaratan ISO/IEC 27001 secara bertahap.

4. Manfaat yang Diharapkan

Manfaat berikut diharapkan dapat dicapai melalui implementasi roadmap ini secara bertahap, seiring dengan meningkatnya struktur, kejelasan, dan konsistensi dalam tata kelola risiko siber di DPMPTSP dengan mengikuti tahapan dibawah ini:

- Meningkatkan visibilitas risiko siber dan kejelasan tanggung jawab.
- Mengurangi ketergantungan pada praktik informal dan ad-hoc.
- Meningkatkan kesiapan dalam menghadapi insiden dan gangguan layanan.
- Mendorong peningkatan kematangan tata kelola secara berkelanjutan.

5. Penutup

Roadmap ini menekankan pendekatan yang praktis dan berkelanjutan. DPMPTSP dapat meningkatkan tata kelola risiko siber secara bertahap tanpa menimbulkan beban operasional atau administratif yang berlebihan.